

TP - Pentest

M. PERDIGON - Cybersécurité



Contexte

Un **pentest** (ou test d'intrusion) est une méthode utilisée pour évaluer la sécurité d'un système informatique, d'un réseau ou d'une application en simulant une attaque par un utilisateur malveillant. Le but est d'identifier les vulnérabilités qui pourraient être exploitées par des attaquants et de recommander des mesures pour les corriger. Le pentest est réalisé par un hacker de type White Hat (les gentils).

Il y a trois types d'approches lors d'un Pentest :

- **Black box** : L'équipe de test n'a aucune information préalable sur le système cible, tout comme un attaquant externe qui n'aurait pas d'accès privilégié.
- **Grey box** : L'équipe de test a un accès partiel aux informations sur le système cible, généralement des informations d'un utilisateur ayant un accès limité (comme un utilisateur interne ou un employé).
- **White box** : L'équipe de test a un accès complet à toutes les informations sur le système cible, y compris le code source, l'architecture du réseau, et les configurations de sécurité.

Pour ce TP, vous serez en **Grey box**, certaines informations vous seront fournies afin de vous accompagner dans le test de pénétration.

1. Installation de Kali Linux

1.1) Créez une VM avec les paramètres suivants :

- 4 vCPU
- 4 Gio de RAM
- 40 Gio d'espace disque
- Réseau : accès par pont
- ISO : Kali

1.2) Une fois l'installation terminée, installez les additions invités (*voir Installation des additions invités sur VirtualBox.pdf*).

ETAPE DE VÉRIFICATION 1 : Appelez le professeur

2. Attaque par dictionnaire

Afin de pouvoir entrer dans le réseau à tester, vous allez passer par la borne Wifi, vous devez ainsi scanner le réseau afin de récupérer le SSID de la borne pour pouvoir l'attaquer.

2.1) Lancez un terminal en root et entrez la commande suivante qui vous affichera votre carte Wifi.

```
airmon-ng
```

2.2) Passez la carte en mode monitor

```
airmon-ng start wlan0
```

2.3) Capturez le trafic Wifi

```
airodump-ng wlan0mon
```

Quel est le canal utilisé pour la diffusion du SSID de l'entreprise cible ?	canal 11
Quelle méthode de chiffrement utilise-t-il ?	WPA2

Quel type d'authentification utilise-t-il ?	PSK
Par quel BSSID est-il identifié en couche 2 ?	EC:08:6B:54:44:C8

2.4) Vous devez maintenant capturer le trafic de ce SSID uniquement.

```
airodump-ng -c <NuméroDeCanal> -bssid <BSSID> -write capture wlan0mon
```

Demander au professeur de se connecter à la borne Wifi afin de récupérer l'adresse Mac cliente, qui va nous permettre de cracker la clé.

2.5) Ouvrez un deuxième terminal et tapez la commande suivante :

```
aireplay-ng -0 2 -a <BSSID> -c <@MacProf> wlan0mon
```

Cette requête va permettre de "dé-authentifié" le client afin de récupérer des informations précieuses pour la connexion.

2.6) Retournez sur le 1er terminal, tapez **Ctrl + C** pour arrêter la commande. Trouvez le fichier de sortie.

Maintenant, il faut effectuer une analyse du fichier de capture à l'aide d'un dictionnaire de mot de passe stocké dans **/usr/share/wordlists/rockyou.txt.gz (à dézipper avant)**

2.7) Sans éditer le dictionnaire, trouvez combien de lignes il contient ?

2.8) A l'aide du logiciel **aircrack** vous allez analyser le fichier de capture en essayant de faire correspondre les mots de passe présent dans le dictionnaire, jusqu'à trouver le bon.

```
aircrack-ng -a2 -b <BSSID> -w /usr/share/wordlists/rockyou.txt
```

<FichierDeCapture.pcap>

Soyez patient, vous allez trouver...

2.9) Maintenant que vous détenez le mot de passe, connectez-vous à la borne afin d'entrer dans le réseau.

ETAPE DE VÉRIFICATION 2 : Appelez le professeur

3. Reconnaissance

Vous allez à présent entrer en phase de reconnaissance, vous vous êtes introduit dans le réseau de l'entreprise, vous devez maintenant connaître les appareils qui sont connectés à celui-ci.

3.1) Depuis un terminal, effectuez un scan du réseau à l'aide de **nmap**. Vous devez trouver la bonne commande qui vous permettra de scanner le réseau et les ports ouverts sur les machines afin de pouvoir déterminer quel type d'appareil il s'agit.

ETAPE DE VÉRIFICATION 3 : Appelez le professeur

4. Brute force

Suite à votre scan, vous avez dû vous apercevoir qu'une caméra de vidéo-surveillance est présente dans les locaux. Vous allez donc tenter de prendre la main sur cette caméra.

4.1) Récupérer l'adresse IP de la caméra, et listez les ports ouverts :

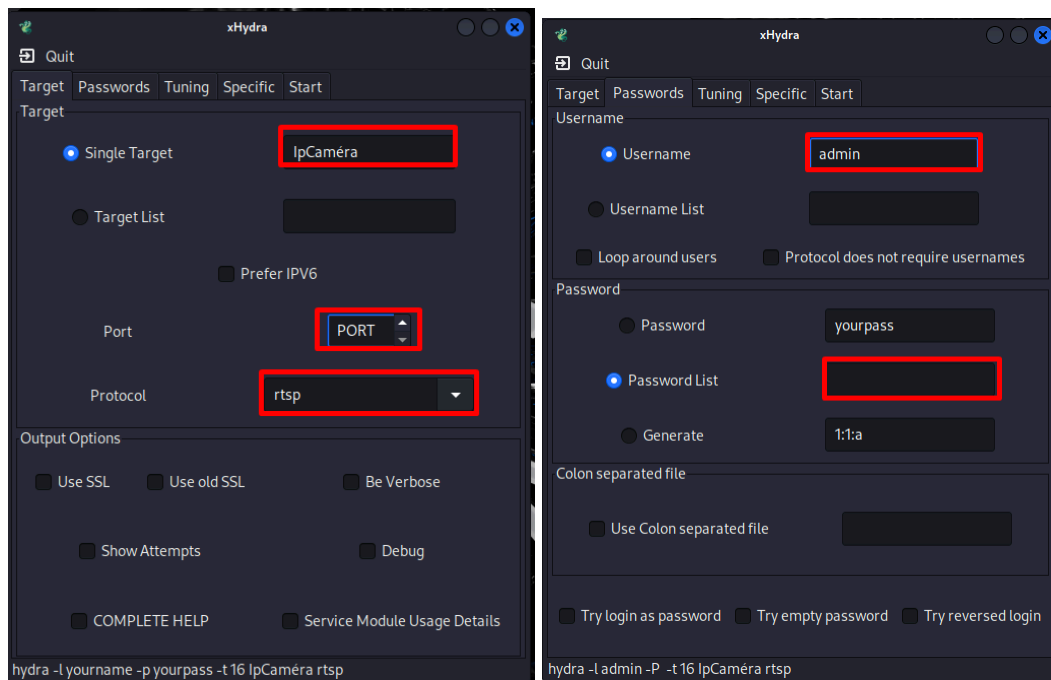
IP	Ports
192.168.2.25	FTP,HTTP,RTSP=21,80,554,49152

4.2) Trouvez le port qui correspond au flux RTSP. A quoi sert ce protocole ?
C'est le port 554 et sa sert a la diffusion en contenu de caméras IP.....
.....

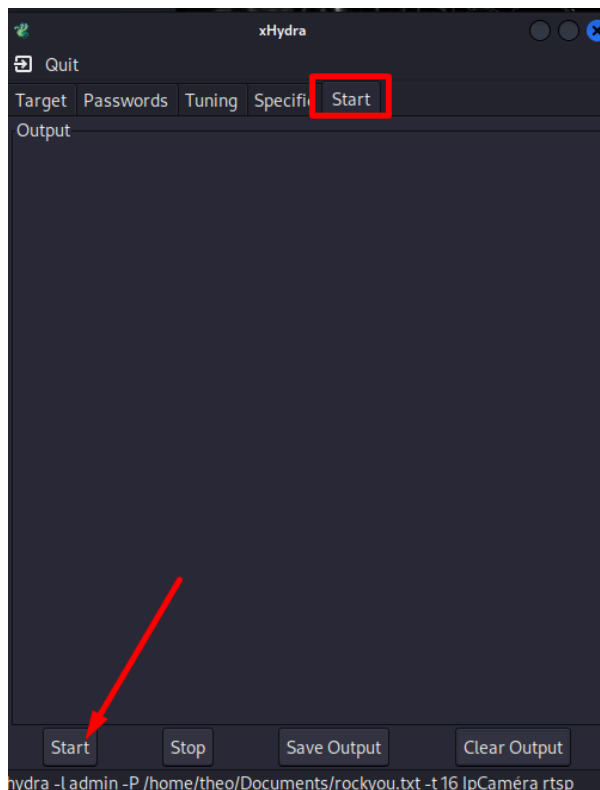
4.3) Ouvrez un terminal en root, et copiez le dictionnaire de mot de passe dans votre répertoire personnel.

4.4) Trouvez le lien RTSP de la caméra à l'aide de son modèle. (axis-...)
tsp://root:admin@192.168.2.25:554/axis-media/media.amp/

4.5) Sur votre VM Kali, lancez le logiciel XHydra, et renseignez les paramètres :



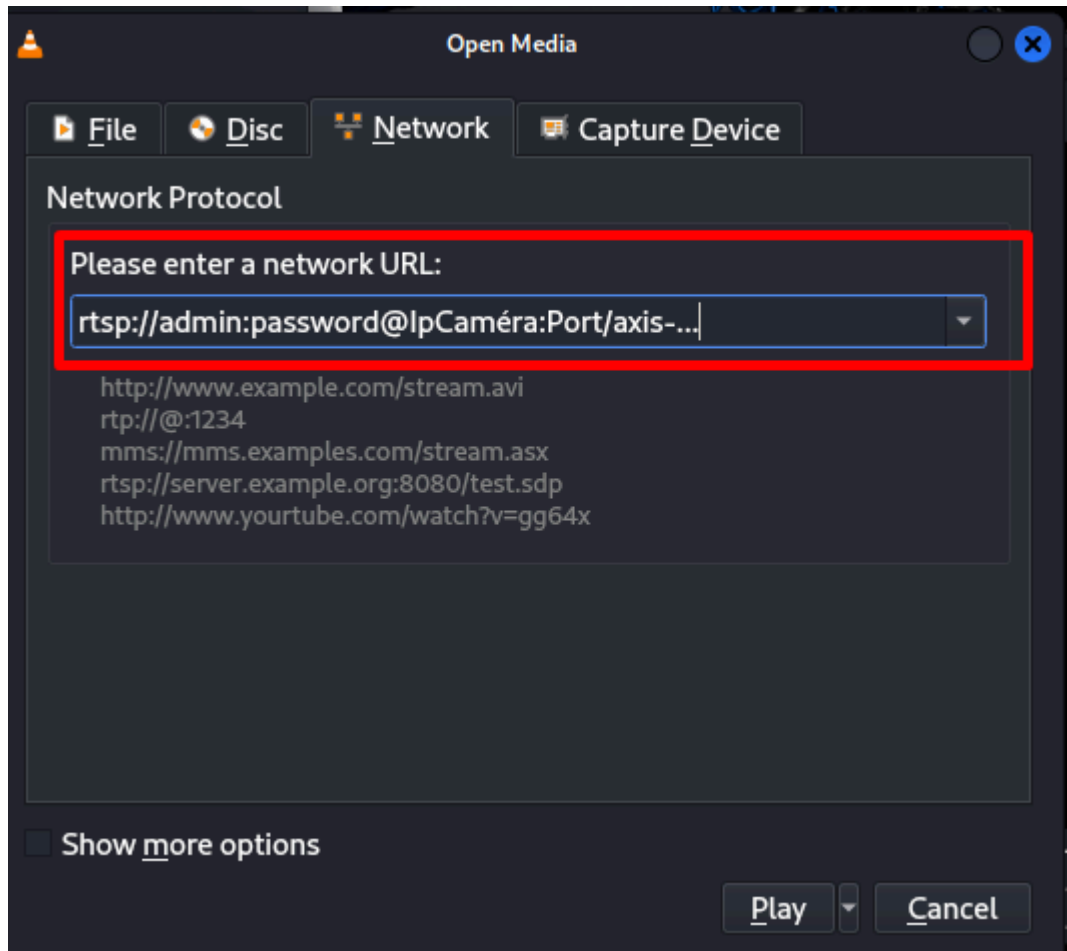
4.5) Lancez l'attaque en force brut



*Nous avons décidé d'utiliser l'utilisateur **root** car il fait partie des plus connus, nous aurions pu aussi utiliser un dictionnaire d'utilisateur.*

4.5) Vous allez maintenant capturer le trafic vidéo, pour cela installez le paquet **vlc**

4.6) Lancez VLC, tapez **Ctrl + N**. Renseignez les bon paramètres.



ETAPE DE VÉRIFICATION 4 : Appelez le professeur

5. Contres-mesures

Grâce à vos nouveaux talents de hacker, vous avez pu vous introduire dans un réseau et pirater une caméra IP. Étant un *white hat*, vous devez maintenant établir des mesures préventives afin de rendre plus compliqués les attaques que vous venez d'effectuer.

5.1) Listez les mesures/configurations possible afin de sécuriser la borne Wifi :

les contre mesure qu'on peut mettre en place c'est

mettre un mot de passe plus sécuriser

mettre un pare feu

ne pas laissé n'importe quelle port ouver

changer le protocole de chiffrement

cachez les adresse MAC

.....

.....

5.2) Listez les mesures/configurations possibles afin de sécuriser la caméra :

les contre mesure qu'on peut mettre en place c'est

mettre un mot de passe plus sécuriser

fermer les port qui sont pas utile

.....

.....

.....

.....

.....

ETAPE DE VÉRIFICATION 5 : Appelez le professeur

6. Recherche de vulnérabilités

Lors de votre scan, vous avez pu constater la présence de plusieurs serveurs web dans le réseau, étant 4 hackers sur le coup, vous aurez un serveur attribué à chacun.

6.1) Effectuez un scan du réseau afin de repérer les serveurs web (qui écoute sur le port HTTP).

6.2) Trouvez le serveur web dont vous voulez vous occuper, un indice dans l'adresse IP vous aidera à choisir le bon.

6.3) Trouvez la version d'Apache2.

6.4) Faites une recherche sur le **CERT-FR** afin de voir s'il existe une vulnérabilité sur cette version d'Apache2.

6.5) Si une vulnérabilité existe, comment faire pour y remédier ?

ETAPE DE VÉRIFICATION 6 : Appelez le professeur

7. Injection SQL

Une source d'information nous indique que ces serveurs web sont précieux car ils contiennent des bases de données comportant un code secret qui vous servira peut-être pour la suite du TP.

Hors l'accès à ce code est protégé par une page de connexion, à vous de contourner celle-ci.

La page étant bloquée par un login et un mot de passe, vous devez trouver le moyen de "bypass" le formulaire afin de pouvoir récupérer le code secret. Pour cela il vous faudra réaliser une injection SQL pour forcer une commande dans le code php.

7.3) Effectuez la bonne injection afin de vous connecter à l'interface. Renseignez votre code.

Champ	Code injecté
Utilisateur	
Mot de passe	

7.4) Quel est le secret récupérer ?

ETAPE DE VÉRIFICATION 7 : Appelez le professeur

8. Remédiations

n

A présent, vous devez sécuriser le serveur web contre les injections SQL afin d'éviter ce type d'attaque à l'entreprise.

8.1) Ouvrez l'archive "remédiations.zip" présente dans votre dossier ressources. Celle-ci vous demandera un mot de passe, un secret ?

8.2) Accédez au serveur web et modifiez le fichier php **authenticate.php**. Réessayez votre attaque et constatez la différence.

8.3) Qu'est-ce qui a changé dans le code php pour contrer l'attaque par injection ?

.....

.....

.....

.....

.....

.....

.....

.....

ETAPE DE VÉRIFICATION 8 : Appelez le professeur

9. Rapport

La dernière partie est l'une des plus importantes suite à un pentest, c'est le rapport d'audit, celui-ci va permettre d'expliquer au client toutes les vulnérabilités trouvées sur son réseau, les explications, et les remédiations que vous avez effectué afin de corriger les failles de sécurité.

Vous trouverez un exemple de rapport dans votre dossier ressource. **Vous devez apporter plus de détails techniques au vôtre** (adresses IP, configurations, version, chemin emprunté...)

Une fois votre rapport terminé, vous enverrez un mail avec un corps professionnel au professeur à l'adresse suivante : perdigon.theo@lpmandesfrance.com

ETAPE DE VÉRIFICATION 9 : Appelez le professeur
